Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad YUSUF DURSUN · 230541104 **Grup** GÜNDÜZ B **Tarih**

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → **FİZİKSEL** sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Vincin kapıları: İnternete açık uzak bakım modülü (4G) · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri · telsiz kumanda — fiziksel sonuç adayları: yükün düşmesi, yükün çarpması/ezmesi, çarpışma.

Görev — üç senaryo kurun ve puanlayın

#	Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
1	**Dış saldırgan** → internete açık 4G uzak bakım modülü + **admin/admin** → yük ölçüm modülünün kalibrasyon katsayısını değiştirir → aşırı yük sınırlayıcı gerçek yükün ancak ~%60'ını okur → vinç kapasite üstü yük kaldırır → halat/fren/kiriş zorlanır, yük düşer → **altındaki çalışan ölür veya ağır yaralanır**.	2	3	3	**18**	**Kritik**
2	**Tesis yakınındaki yetkisiz kişi** → Wi-Fi (kartondaki parola) → HMI port 80 (kimlik doğrulamasız) → hız rampalarını ve sallanma azaltmayı değiştirir → ani hızlanma/duruşta yük sallanır → **sapancıya çarpma, istif arasında sıkışma**.	3	2	2	**12**	**Yüksek**
3	**Bakım yüklenicisi (farkında olmadan)** → kilitsiz USB → HMI'ya zararlı yazılım → PLC'deki yazılımsal üst limit kaldırılır → donanımsal son limit yoksa kanca üst noktaya çarpar (iki blok) → halat kopar → **yük düşer**.	1	3	2	**6**	**Orta → S=3 öne alındı**

Kritik 18–27 **Yüksek 9–17** **Orta 4–8** Düşük 1–3 · L = olasılık · S = şiddet · E = maruziyet

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

Senaryo 1 — internete açık modül ve varsayılan parola istismarı çok kolaylaştırıyor, sonuç ana emniyet fonksiyonunu (aşırı yük sınırlama) sessizce devre dışı bırakıyor ve yük düşmesi doğrudan ölümle sonuçlanabiliyor.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet — **Senaryo 3** (L1×S3×E2 = 6, Orta). Risk kaydında **"S=3 – öne alındı"** kırmızı bayrağıyla skor sırasından bağımsız olarak ilk üçe alınır; **yazılımdan bağımsız, güç devresinde çalışan donanımsal son limit şalteri** ve **USB kilidi** gereksinimleri olarak EP 03'e bağlanır, yönetim gözden geçirmesinde ayrıca raporlanır.

Altın kural: *Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — üç senaryonun da son halkası insana olan fiziksel etkidir.*

📄 Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.